

# Network Traffic Analysis Incident Report ---

## 2024-09-04

Analyst Name : Nizar Aderbaz

### 1. Executive Summary :

On **September 4th, 2024**, one of our internal systems was **compromised**. The system attempted to exploit internal network resources and communicated with **malicious external servers**, indicating the presence of malware.

This incident poses a **high risk to our network and sensitive data**, and immediate action was taken to **isolate the affected system and prevent further impact**. Further investigations are underway to understand the scope of the compromise and strengthen our defenses.

### 2. Incident Timeline :

| Time (UTC)       | Source → Destination        | Protocol / Port   | Event ID | Event / Alert                                           | Description / Context                                               |
|------------------|-----------------------------|-------------------|----------|---------------------------------------------------------|---------------------------------------------------------------------|
| 2024-09-04 17:33 | 172.17.0.99 → 172.17.0.17   | TCP / 49769 → 139 | 3.1383   | Potentially unsafe SMBv1 protocol                       | Legacy SMBv1 usage detected, high-risk protocol                     |
| 2024-09-04 17:33 | 172.17.0.99 → 172.17.0.17   | TCP / 49769 → 139 | 3.1384   | SMB Session Setup NTLMSSP unicode ASN1 overflow attempt | SMB buffer overflow attempt, potential remote code execution        |
| 2024-09-04 17:33 | 172.17.0.99 → 172.17.0.17   | TCP / 49769 → 139 | 3.1386   | SMB IPC\$ unicode share access                          | Attempt to access administrative SMB share                          |
| 2024-09-04 17:33 | 172.17.0.99 → 172.17.0.17   | TCP / 49769 → 139 | 3.1387   | SMB_COM_TRANSACTION Max Data Count DOS attempt          | Denial-of-service attempt via SMB overflow                          |
| 2024-09-04 17:34 | 172.17.0.99 → 172.17.0.17   | TCP / 49774 → 88  | 3.1456   | RPC Kerberos principal name overflow                    | Buffer overflow attempt against Kerberos (domain controller target) |
| 2024-09-04 17:35 | 172.17.0.99 → 79.124.78.197 | TCP / 49813 → 80  | 3.1497   | Suspicious POST to external IP with fake browser        | Potential data exfiltration or C2 communication                     |
| 2024-09-04 17:35 | 172.17.0.99 → 79.124.78.197 | TCP / 49813 → 80  | 3.1504   | Win32/Koi Stealer CnC Checkin (POST)                    | Malware beaconing to C2 server, active compromise indicator         |

### **Victim System Information :**

- **Hostname** : DESKTOP-RNVO9AT
- **Internal IP** : 172.17.0.99
- **MAC Address** : 18:3d:a2:b6:8d:c4
- **Windows User** : Andrew Fletcher (afletcher)

---

## 2. Indicators of Compromise (IOCs) :

### 4.1 Domains :

- **www[.]bellantonicioccolato[.]it** (VirusTotal: **0/95 detections**, but ForcePoint ThreatSeeker flags it as **suspicious**)

### 4.2 IP Addresses :

- **79.124.78.197** (VirusTotal : **3/95** | AbuselpDb : **Not Found** | ThreatFox : flagged as **KoiLoader Malware**)

### 4.3 URLs :

- **hxxp[:]//[.]79[.]124[.]78[.]197/foots[.]php**

### 4.4 Hashes :

- None found in this analysis

---

## 3. Conclusion :

On **September 4th, 2024**, one of our internal hosts (**172.17.0.99**) showed signs of serious malicious activity. The alerts indicate that someone—or something—was actively trying to exploit vulnerabilities in our network:

- **Inside the network:** The host attempted several **SMB attacks**, including buffer overflow attempts and unauthorized access to administrative shares. It also tried to exploit **Kerberos authentication**, which could allow an attacker to gain higher privileges or disrupt the domain controller.
- **Outside the network:** The same host made suspicious **HTTP POST requests** to an external IP, including activity linked to **malware command-and-control servers**, suggesting possible malware infection and data exfiltration.

**What this means:** The host is likely **compromised**. It was trying both to attack internal systems and communicate with malicious servers outside. This is a **high-severity incident** that could put the network at risk.

---

#### 4. Recommendations :

- **Isolate the affected host** immediately.
- **Run full malware and forensic scans** on the host.
- **Check domain controller logs** for unusual Kerberos activity.
- **Block any suspicious external IPs** to prevent further communication.
- **Review and secure SMB usage** across the network.
- Keep detailed logs and captures for further investigation

